

Manager Access Bugs and Edge Cases Report

QA audit date: 2026-07-29 | Important bugs and edge cases only | No code changed

Module	Severity	Main bug	Important edge case	Best solution
Dashboard	Medium	Customer conversion can undercount Manager direct/team wins. Follow-up cards can include inaccessible prospects.	No Executives, moved Executive, lead assigned by Admin.	Use one Manager scope rule and align follow-up access.
Notifications	Medium	Links can send Manager to Settings or records they cannot access.	Lead reassigned away, follow-up assigned but prospect owned elsewhere.	Build links using current access rules.
Users/Executives	Critical	Direct API actions can manage any same-org Executive if ID is known, not only direct reports.	Manager A edits/disables Manager B Executive; managerId change.	Add server-side direct-report checks to every user action.
Leads	Critical	Manager can assign leads to any org Executive. Dropdown leaks other teams. Delete action is visible but backend denies.	Assign outside team, lead disappears after assignment, cross-org item ID.	Scope assignable users to self/direct reports and hide invalid actions.
Prospects	High	Prospect/follow-up assignment inherits the lead assignment bug. Follow-up owner can differ from prospect owner.	Follow-up outside team, terminal won/lost prospect.	Use strict Manager assignee validation and align follow-up access.
Quotations	High	Status and delete actions can be visible even when backend rejects them. Reject dialog has no reason field.	Approve own quote, reject without reason, approved quote edit.	Match UI to backend transition rules and add reason input.
Customers	Medium	Customer totals can differ between dashboard, customers, and reports. Approved quote may not create customer.	Manager direct customer, Admin-assigned team customer.	Use one customer conversion rule and Manager scope.
Reports	High	Executive filter can expose all org Executives through shared assignable-users endpoint. Exports lack strong audit.	Filter other-team Executive, export team data, large date range.	Validate executiveId against direct team, cap limits, audit exports.
Profile	High	Password change is hidden in UI but direct route/API can still work. Asset permission is broader than UI.	Open change-password URL, crafted asset upload.	Enforce password and asset rules in backend.
Settings	Medium	Settings is requested for Manager but route/sidebar block it.	Direct /settings URL, notification link, lapsed subscription banner.	Add restricted Manager settings or remove from docs/module list.
Help	Low	Help says Executives in organization, but rule should be direct-report Executives only.	Search assign Executive, quotation approval, settings.	Update Manager FAQs after permission fixes.